1.6 Test de intrusión

Para evaluar la fortaleza de los sistemas de seguridad, se usan herramientas para atacar, los llamadas test de intrusión o **pentest**, que pretenden evaluar el estado de los sistemas frente a cualquier ataque de tipo intrusivo.

Estos servicios, conocidos como servicios de **hacking ético**, dan los mismos pasos que un atacante con malas intenciones, buscando vulnerabilidades que aprovechar y realizando ataques controlados sobre los sistemas, que se pueden llevar a cabo remotamente desde el exterior o en el interior de la propia red.

Para desarrollar estos ataques, se usan herramientas propias del hacking.

Este proceso pasa por las siguientes fases:

- **Análisis de la Información pública**: se debe tener un buen conocimiento sobre los sistemas objetivo, de toda la información que publican en la red. Hay que conocer las herramientas para la obtención de la máxima información sobre webscorporativas, metadatos, redes sociales, ofertas de trabajo, listas negras, foros y webs externas.
- **Análisis de seguridad de red**: se recolecta Información y políticas de control. Se obtiene la máxima Información posible sobre el hardware del que dispone la red y el software explotado en la misma: sondeo de red, mapa de red, escaneo de puertos. Identificación de servicios y de los sistemas operativos desplegados.
- **Análisis de seguridad de sistemas**: se buscan vulnerabilidades haciendo un análisis exhaustivo de las actualizaciones y sus configuraciones, identificando las vulnerabilidades no publicadas y analizando los sistemas de autenticación.
- **Análisis de seguridad de aplicaciones**: se estudian las aplicaciones accesibles desde Internet buscando mecanismos para comprometer la seguridad de las aplicaciones. Para ello, se hace un inventario de todas las afectadas sin disponer de información sobre credenciales de autenticación ni el código fuente de las mismas. Luego, se lleva a cabo un análisis de la configuración, de los sistemas de autenticación, de los esquemas de autorización, de la gestión de sesiones y de los mecanismos de validación de los datos.
- **Análisis de los sistemas de seguridad**: se analizan los dispositivos y herramientas que no están bien configurados: cortafuegos, sistemas de detección y protección de intrusos, software antivirus y antimalware.

1.7.1. Búsqueda de información pública

El proceso de recogida de información en internet se conoce como ***footprinting***. Generalmente, se buscan huellas del tipo direcciones IP, cuentas de correo de usuarios, credenciales, metadatos, etc. La huella digital, también llamada ***fingerprinting***, es un mecanismo para defender los derechos de autor y combatir la copia no autorizada de contenido puede ser usada en seguridad para detectar copias ilegales.

Característica	Footprinting	Fingerprinting
Fase	Inicial (Reconocimiento amplio)	Posterior (Identificación detallada)
Objetivo	Recopilar información general (dominios, IPs, nombres, correos).	Identificar específicamente (versiones de SO, software, servicios).
Interacción	Baja o nula (uso de fuentes abiertas - OSINT).	Alta (interacción directa y análisis de respuestas del sistema).
Similitud	Es como buscar la dirección de una casa.	Es como determinar la marca y modelo de la cerradura de la puerta.

Ejercicio 9.

Busca información de las siguientes aplicaciones. Por cada una de ellas indica

- Nombre de la aplicación
- Características (4-5 líneas)
- Utilización práctica (para qué se utiliza principalmente)
- Fuente consultada (de dónde has obtenido la información).

Aplicaciones:

- Anubis
- Foca
- Maltego
- Nessus
- Qualys

1.7.2 Análisis de vulnerabilidades con nmap

Network mapper (nmap) es una herramienta multiplataforma que permite realizar auditorías de seguridad en red. Rastrea y analiza en busca de sistemas para elaborar un inventario de red. La información que se puede mostrar con este comando es la siguiente:

- hosts activos en la red

- sistema operativo que se está ejecutando
- puertos y servicios abiertos a través de la red
- tipos de cortafuegos
- etc

El escaneo de puertos debe hacerse con autorización del propietario deldominio web. De lo contrario, podría incurrirse en un delito. Por ejemplo, en auditorías de seguridad, el Nmap es una de las primeras herramientas que se ponen en práctica para recolectar datos sobre el sistema.

Nmap nos da información sobre las direcciones IP de todos los puertos abiertos, cerrados e indeterminados, de un dominio web. La razón por la cual esto es útil es debido a que, por ejemplo, puede que no exista un fallo en el puerto 80/tcp open http, pero puede que sí lo haya en la IP del 53/tcp open domain.

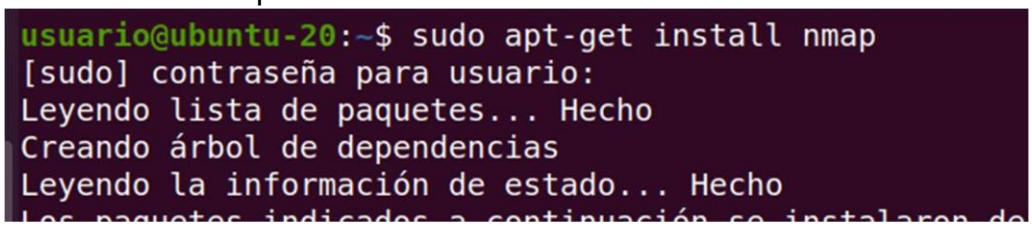
Tema 1. Introducción a la seguridad

Ejercicio 10.

Completa la tabla con la información de los principales puertos y protocolos asociados:

Puerto	Nombre	Descripción
20		
21		
22		
23		
25		
53		
80		
101		
110		
143		
443		
465		
587		
993		
995		
3306		
3389		
25565		

Para instalar nmap



Comandos para lanzar nmap:

Como Usar NMAP en LINUX para ESCANEAR PUERTOS de una Dirección IP
https://www.youtube.com/watch?v=8n-GfcPOM_I

nmap y la red a escanear

Escanear puertos abiertos:

```
vboxuser@Ubuntu07:~$ nmap 192.168.0.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2024-09-29 19:34 CEST
Nmap scan report for mygpon (192.168.0.1)
Host is up (0.015s latency).
Not shown: 997 filtered ports
PORT    STATE SERVICE
53/tcp  open  domain
80/tcp  open  http
443/tcp open  https

Nmap scan report for 192.168.0.11
Host is up (0.064s latency).
Not shown: 998 filtered ports
PORT    STATE SERVICE
22/tcp  open  ssh
443/tcp open  https

Nmap done: 256 IP addresses (2 hosts up) scanned in 41.79 seconds
vboxuser@Ubuntu07:~$
```

Ver los ordenadores conectados a mi red:
Añadimos -sn

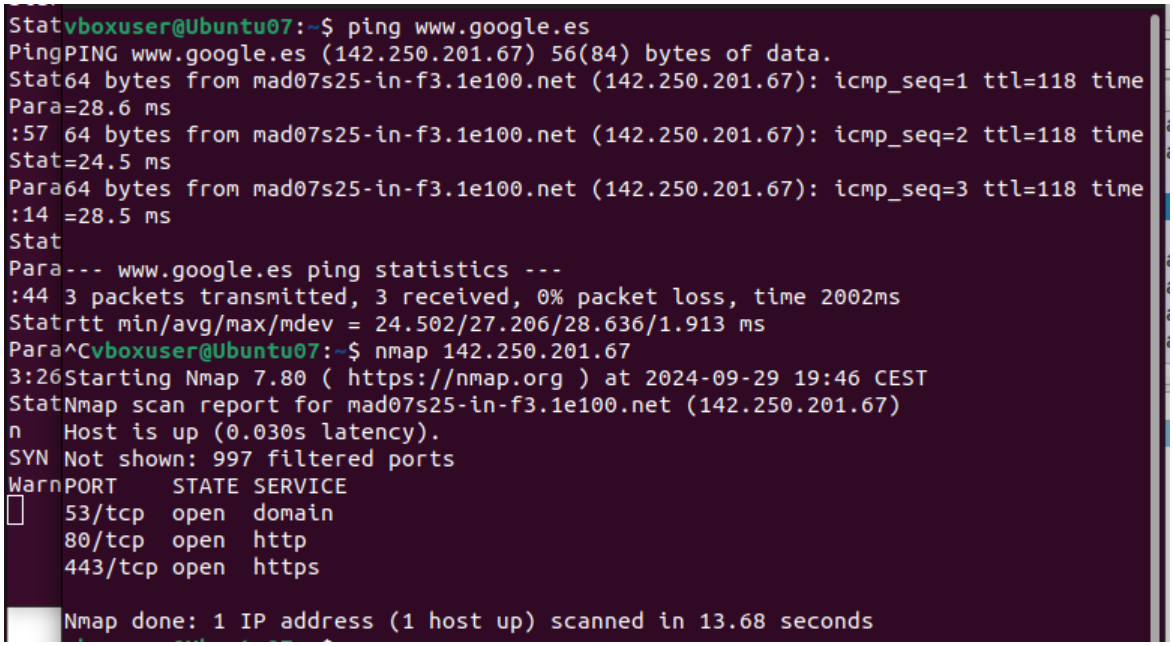
```
vboxuser@Ubuntu07:~$ nmap -sn 192.168.0.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2024-09-29 19:38 CEST
Stats: 0:00:08 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Parallel DNS resolution of 256 hosts. Timing: About 50.00% done; ETC: 19:38 (0:0
0:05 remaining)
Stats: 0:00:13 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Parallel DNS resolution of 256 hosts. Timing: About 50.00% done; ETC: 19:38 (0:0
0:10 remaining)
Nmap scan report for mygpon (192.168.0.1)
Host is up (0.012s latency).
Nmap scan report for 192.168.0.11
Host is up (0.031s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 16.04 seconds
```

Ver qué sistemas operativos tienen los ordenadores conectados a mi red:
Añadimos -O

```
vboxuser@Ubuntu07:~$ sudo nmap -O 192.168.0.0/24
```

Podemos ver qué puertos tiene abiertos un recurso en internet, en este ejemplo hacemos ping a Google para ver su IP y posteriormente ejecutamos nmap sobre la IP

Y podemos ver qué puertos tiene abiertos


vboxuser@Ubuntu07:~$ ping www.google.es
PING www.google.es (142.250.201.67) 56(84) bytes of data.
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=1 ttl=118 time=28.6 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=2 ttl=118 time=24.5 ms
64 bytes from mad07s25-in-f3.1e100.net (142.250.201.67): icmp_seq=3 ttl=118 time=28.5 ms
--- www.google.es ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 24.502/27.206/28.636/1.913 ms
^Cvboxuser@Ubuntu07:~$ nmap 142.250.201.67
Starting Nmap 7.80 (https://nmap.org) at 2024-09-29 19:46 CEST
Nmap scan report for mad07s25-in-f3.1e100.net (142.250.201.67)
Host is up (0.030s latency).
Not shown: 997 filtered ports
PORT STATE SERVICE
53/tcp open domain
80/tcp open http
443/tcp open https
Nmap done: 1 IP address (1 host up) scanned in 13.68 seconds